

Employee Ideation Tool

Software Requirements Specification

System	IFQM Employee Ideation Tool (EIT) - a multi-tenant platform on which member organisations collect, review, approve and track employee improvement ideas.
Document	Software Requirements Specification. States what the system must do and how well, separately from how it is built - that is the Software Architecture document.
Audience	IFQM, member organisations evaluating the platform, and the team building and testing it.
Status	Describes the system as built. Requirements not yet met are listed in section 8 rather than omitted.
Version	Updated 15 August 2026.

Counted from the repository for this version: 159 HTTP endpoints across 20 route files, 40 backend services, 31 screens, 15 registry tables and 17 tables in each organisation database, 24 schema migrations, 1,371 translated strings in each of 7 languages, and 248 executed test cases of which 248 pass.

Contents

1. Introduction	3
1.1 Purpose	3
1.2 Scope	3
1.3 Definitions	3
1.4 References	4
2. Overall description	5
2.1 Product perspective	5
2.2 User classes	5
2.3 Operating environment	5
2.4 Constraints	5
2.5 Assumptions and dependencies	5
3. External interface requirements	7
3.1 User interface	7
3.2 Software interfaces	7
3.3 Communications	7
4. Functional requirements	8
4.1 Authentication and sessions	8
4.2 One-time codes, by text and by email	8
4.3 Ideas	9
4.4 Review and approval	9
4.5 Participation	10
4.6 Organisation administration	10
4.7 Platform administration	10
4.8 Maintenance mode	11
4.9 Integration, reporting and billing	11
5. Non-functional requirements	12
5.1 Security	12
5.2 Performance and capacity	12
5.3 Reliability and availability	12
5.4 Usability, accessibility and operability	13
5.5 Privacy	13
6. Data requirements	14
7. Verification	15
8. Requirements not fully met	16

1. Introduction

1.1 Purpose

This document states what the Employee Ideation Tool is required to do, and how well it is required to do it. It is written to be read by people who will use, buy, build or test the system, which means requirements are stated in plain language and a technical term is explained in the sentence that introduces it.

It is deliberately separate from the Software Architecture document. This one says what must be true; that one says how it is achieved. Where a requirement exists because of a specific failure or a specific attack, the reason is given - a requirement whose purpose is unknown is the first one somebody removes.

1.2 Scope

The system collects improvement ideas from employees, routes them to the right reviewers, records the decision, and hands approved ideas to a separate implementation system. It serves many member organisations at once, each with its own users, data and settings, and each unable to see any other.

In scope:

- Submission, review, approval and tracking of ideas, including drafts, attachments, co-suggesters, categories and time-bound challenges.
- Participation: voting, comments, points and leaderboards.
- Organisation administration: users, reporting lines, categories, approval stages, branding and email settings.
- Authentication by password and by one-time code sent as a text message or an email.
- Platform administration: creating and suspending organisations, subscription and billing, delivery configuration, and putting the whole platform on hold for maintenance.
- Reporting, export and an audit trail.

Out of scope:

- Implementing the approved idea. That is done in QCMS, a separate system, to which approved ideas are pushed.
- Payroll, HR records and any authoritative employee master data. Users are imported.
- Anonymous public submission from outside a member organisation.

1.3 Definitions

Term	Meaning
Tenant / organisation	One member organisation. Each has its own database, so no query can reach another organisation's data even if the code asking is wrong.
Platform administrator	IFQM staff. Administers organisations; cannot read the ideas inside them.
Organisation administrator	Runs one organisation: its people, settings and categories.

Term	Meaning
One-time code (OTP)	A six-digit secret sent to a mobile number or email address and exchanged for a session. Valid once, for a few minutes.
DLT	The registration regime Indian mobile operators require before they will carry commercial text messages. An unregistered message is discarded by the carrier.
Sender ID / header	The six-character name a recipient sees instead of a phone number.
Content template	Wording approved in advance by the operator, with placeholders. The text sent must match it.
SLA	The number of days a reviewer has before an idea is flagged overdue.
QCMS	The Quality and Continuous improvement Management System where approved ideas are implemented and tracked.
Maintenance mode	A platform-wide hold during which no member organisation can sign in and IFQM staff still can.

1.4 References

- Software Architecture document - how these requirements are realised, with diagrams.
- User Guide - the same system described as tasks, for the people who operate it.
- Test Cases document - the 248 executed cases and their recorded results.
- Security Features document - the security posture in detail.

2. Overall description

2.1 Product perspective

The system is a browser application backed by an HTTP API and a set of MySQL databases. It holds one registry database recording which organisations exist, and one separate database per organisation holding that organisation's people and ideas. Separation is physical rather than a column in a shared table, because a missing filter in a shared table is a data breach whereas a missing filter against a separate database returns nothing.

It integrates outward only. Nothing external calls into it. Four outbound integrations exist - an SMS gateway, a mail sender, QCMS and an optional AI scorer - and all four are optional in the sense that the system continues to work, with reduced function, when any is absent.

2.2 User classes

Class	Characteristics	What they need most
Employee	Any member of a member organisation. Not assumed to be a confident computer user; may be working on a phone on a shop floor.	To submit an idea in a few minutes without training, in their own language.
Reviewer / manager	Decides on ideas from the people who report to them.	A queue that makes overdue work obvious.
Organisation administrator	Runs the scheme for one organisation.	Bulk user import, reporting lines, categories, and settings that do not need IFQM.
Platform administrator	IFQM staff, small in number.	To create and support organisations without ever reading their ideas.

2.3 Operating environment

- Client: any current browser on desktop, tablet or phone. No installation, no plug-in.
- Server: Node.js running an Express application, behind HTTPS.
- Data: MySQL 8. The registry and every organisation database live on the same server instance in the current deployment.
- Delivery: an Indian DLT-registered SMS gateway for text, and SMTP or the mail provider's HTTPS API for email.

2.4 Constraints

- Indian mobile operators discard commercial text that is not registered in advance, so message wording is configuration rather than source code and must match the approved template exactly.
- Some hosting providers block outbound SMTP entirely. Email delivery must therefore not depend on SMTP alone.
- The free hosting tier used for the current deployment sleeps when idle and has an ephemeral disk, so uploaded files do not survive a restart.
- Money is held as a whole number of paise. A price is an exact quantity and floating point is not.

2.5 Assumptions and dependencies

- Employee records are created by an organisation administrator, by import or individually. Nobody self-registers as an employee.
- An organisation applying to join can receive both an email and a text message, since it must prove it holds both before its application is accepted.
- The sending domain stays verified with the mail provider. If it lapses, every message is rejected regardless of anything in this system.

3. External interface requirements

3.1 User interface

- Every screen must work at phone width. The idea form runs one step to a screen on a small display.
- The entire interface must be available in English, Hindi, Kannada, Malayalam, Marathi, Tamil and Telugu. The choice is remembered per device and changes labels, not content other people have written.
- No screen may report failure without saying what to do next. "Something went wrong" is not an acceptable message.

3.2 Software interfaces

Interface	Direction	Requirement
SMS gateway	Outbound	Sends a one-time code by text. Must carry the entity, sender and content-template registrations the operator requires. Must record every attempt without storing the message body.
Mail - SMTP	Outbound	Sends codes, reset links and notifications. TLS required; a server presenting an unverifiable certificate must be refused, not accepted.
Mail - HTTPS API	Outbound	The same messages over port 443, used where the host blocks outbound SMTP. Must be usable without changing any other setting.
QCMS	Outbound	Receives approved ideas. A duplicate must be treated as success - the idea has arrived, and retrying would create a second.
AI scorer	Outbound	Optional. With none configured, no idea text may leave the system at all and scoring runs locally.

3.3 Communications

- All client traffic over HTTPS.
- The API is stateless and authenticated by a signed token carried in a header.
- Cross-origin requests are permitted only from an explicit list of front-end addresses.

4. Functional requirements

Requirements are numbered FR-n.m and grouped by area. The right-hand column names the module in the Test Cases document that exercises the requirement; every requirement here is covered by at least one executed case.

4.1 Authentication and sessions

ID	Requirement	Verified by
FR-1.1	A user signs in with an email address or a registered mobile number and a password. The organisation code is optional where the identifier belongs to only one organisation.	Authentication
FR-1.2	A failed sign-in must not reveal whether the account exists. The message and the time taken must be the same for an unknown account as for a wrong password.	Authentication, Safety & Data Protection
FR-1.3	Five consecutive failures lock the account for fifteen minutes. The counter must survive a server restart and be shared across servers.	Authentication
FR-1.4	A session expires after a period of inactivity, and immediately when the password changes or the account is deactivated - on every device.	Authentication
FR-1.5	A user on a temporary password may reach nothing except the change-password screen and support, enforced by the server.	Authentication
FR-1.6	A user may reset a forgotten password by an emailed link valid for one hour and usable once, or by a one-time code where the mailbox cannot be reached.	Authentication, One-Time Codes

4.2 One-time codes, by text and by email

A one-time code is a six-digit secret sent to something the person already holds and exchanged for a session, or for proof that they own an address or a number. The same rules apply wherever a code is used.

ID	Requirement	Verified by
FR-2.1	A user may sign in with a code instead of a password. The resulting session must be indistinguishable from a password session - no downstream feature may behave differently.	One-Time Codes
FR-2.2	A code is sent by text when the person supplied a mobile number and by email when they supplied an address. The other channel may be used only when the first cannot deliver at all, and the substitution must be recorded.	One-Time Codes
FR-2.3	Codes are stored hashed. No column anywhere may hold the digits, and the message body must never be written to any log.	One-Time Codes, Safety & Data Protection
FR-2.4	A code is drawn from a cryptographic random source, is valid for a configurable window defaulting to five minutes, and may be redeemed exactly once.	One-Time Codes
FR-2.5	Wrong guesses are counted against the individual code. Reaching the limit (default five) destroys that code rather than leaving it live with the counter pinned.	One-Time Codes

ID	Requirement	Verified by
FR-2.6	Issuing a new code expires any code still outstanding for the same identifier, so resending never widens the range an attacker may guess within.	One-Time Codes
FR-2.7	Requesting a code must answer identically whether or not the identifier is registered, and must write no record for an unregistered one.	One-Time Codes
FR-2.8	A further request within the resend interval is refused, and the reply states how long remains.	One-Time Codes
FR-2.9	The sign-in screen offers the code option only when a code can actually be delivered.	One-Time Codes
FR-2.10	Every send attempt is recorded with the outcome, the purpose, the template used and the recipient masked to its last four digits.	One-Time Codes, Observability
FR-2.11	The text sent must match the wording registered with the operator for the template it claims, placeholder for placeholder.	One-Time Codes
FR-2.12	An organisation applying to join must verify both its contact email address and its contact mobile number by code before the application can be submitted, and the outcome is recorded on the application.	One-Time Codes
FR-2.13	The registration form - unlike sign-in - reports honestly whether a code was sent, because the applicant is typing their own details.	One-Time Codes

Why requesting a code must say nothing

Anything that answers differently for a registered number than for an unregistered one turns the sign-in page into a directory: type numbers, learn who works there. FR-2.7 is the reason the reply is deliberately unhelpful, and the reason no row is written for an unknown identifier - a timing difference would leak the same fact.

4.3 Ideas

ID	Requirement	Verified by
FR-3.1	An employee submits an idea with, at minimum, a title, the present situation and a proposed solution. Everything else is optional.	Ideas
FR-3.2	An idea may be saved as a draft, visible only to its author and their administrator.	Ideas
FR-3.3	Input is validated before it reaches the database. A field longer than its column must be refused with a message naming the limit, never a server error.	Ideas
FR-3.4	Attachments are restricted by real type and size, checked on the server. Renaming a file must not change what it is taken to be.	Ideas, Safety & Data Protection
FR-3.5	Similar existing titles are shown as a warning at submission. It must never block submission.	Ideas
FR-3.6	Each submitted idea receives a permanent identifier.	Ideas
FR-3.7	Browse and list responses must not carry full idea text; truncating on screen is not privacy.	Safety & Data Protection

4.4 Review and approval

ID	Requirement	Verified by
FR-4.1	An idea is routed to the reviewer configured for its author, and passes through the approval stages the organisation has defined.	Review & Approval
FR-4.2	Nobody may decide on their own idea.	Review & Approval
FR-4.3	An organisation administrator may not approve or otherwise act on a submitted idea; administration and adjudication are separate.	Review & Approval
FR-4.4	A rejection requires a comment.	Review & Approval
FR-4.5	A decision writes the status and the audit entry together, or neither. A decision is never half-recorded.	Data Integrity & Recovery
FR-4.6	Concurrent decisions on the same idea result in exactly one recorded approval.	Reliability & Fault Tolerance
FR-4.7	An idea not decided within the configured SLA is flagged overdue.	Review & Approval

4.5 Participation

ID	Requirement	Verified by
FR-5.1	Users may vote on ideas, once each, and may withdraw a vote.	Voting & Community
FR-5.2	Users may comment on ideas visible to them.	Comments
FR-5.3	Points are awarded for submission, approval and implementation, at rates the platform sets, and are shown on a leaderboard.	Voting & Community
FR-5.4	A user may not alter their own role, points or reporting line; attempts from the browser are refused by the server.	Safety & Data Protection

4.6 Organisation administration

ID	Requirement	Verified by
FR-6.1	An administrator creates users individually or by spreadsheet import, with a derived temporary password that must be changed at first sign-in.	Org Admin / Users
FR-6.2	A mobile number is required for every user, so that a code can always reach them.	Org Admin / Users
FR-6.3	An administrator defines categories, approval stages, the review SLA, branding and the organisation's own mail settings.	Branding & Settings
FR-6.4	Deactivating a user ends their access immediately, without deleting their ideas.	Org Admin / Users

4.7 Platform administration

ID	Requirement	Verified by
FR-7.1	Platform staff create an organisation, which provisions its database and first administrator, and may rename, suspend, reactivate or remove it.	Platform Admin
FR-7.2	Removing an organisation requires typing its code to confirm.	Platform Admin
FR-7.3	Platform staff may not read the ideas, comments or personal data inside any organisation.	Security & Multi-Tenancy

ID	Requirement	Verified by
FR-7.4	Platform staff configure the SMS gateway and the one-time-code policy, and may send a real test message to prove the settings before anybody depends on them.	One-Time Codes, Observability
FR-7.5	Code sign-in cannot be switched on while the chosen provider could not actually deliver.	One-Time Codes
FR-7.6	Platform staff can put the entire platform on hold for maintenance. See 4.8.	One-Time Codes, Platform Admin

4.8 Maintenance mode

ID	Requirement	Verified by
FR-8.1	When maintenance is on, no member organisation may obtain a session - by password or by one-time code.	One-Time Codes
FR-8.2	Sessions opened before maintenance began stop working on their next request.	One-Time Codes
FR-8.3	IFQM platform staff are unaffected and retain full access to the console, so the switch can always be reached to turn it off.	One-Time Codes
FR-8.4	Signing out remains available to a member organisation user, so they can clear a refused session and see the notice.	One-Time Codes
FR-8.5	The sign-in screen displays the notice, which the operator may write, defaulting to standard wording.	One-Time Codes
FR-8.6	If the registry cannot be read, the system must behave as though maintenance is off. It must never be possible for a database fault to create a lockout nobody can clear.	Reliability & Fault Tolerance

4.9 Integration, reporting and billing

ID	Requirement	Verified by
FR-9.1	An approved idea may be pushed to QCMS. Failure is recorded against the idea and may be retried; a duplicate counts as success.	QCMS Integration
FR-9.2	Each organisation holds its own QCMS credentials; they are never shared or returned to the browser.	QCMS Integration, Safety & Data Protection
FR-9.3	Dashboards and reports summarise submissions, decisions, timeliness and participation, and may be exported.	Analytics & Reports, Reports & Export
FR-9.4	An audit trail records who did what and when.	Observability & Operations
FR-9.5	Subscriptions carry a plan, a period, a grace window and reminders; an organisation past its grace window is put on hold and can still pay.	Platform Admin

5. Non-functional requirements

5.1 Security

ID	Requirement	Verified by
NFR-1.1	Passwords are stored using a deliberately slow one-way hash, never reversibly.	Safety & Data Protection
NFR-1.2	One-time codes are stored to the same standard as passwords.	One-Time Codes
NFR-1.3	Authorisation is decided from the database on every request, not from the session token, so removing a user or changing a role takes effect at once.	Security & Multi-Tenancy
NFR-1.4	One organisation must never be able to read another's data, including by altering identifiers in a request.	Security & Multi-Tenancy
NFR-1.5	Secrets - mail passwords, gateway keys, integration tokens - are never returned by any endpoint. A caller may learn only whether one is set.	Safety & Data Protection
NFR-1.6	Saving an unrelated setting must never clear a stored secret. A secret changes only on an explicit new value or an explicit instruction to clear it.	Safety & Data Protection
NFR-1.7	Outbound mail requires TLS and a verifiable certificate.	Safety & Data Protection
NFR-1.8	A provider that writes codes to a log instead of sending them is refused outright in production.	One-Time Codes
NFR-1.9	Uploads are checked by real content type on the server, and are never served in a way that lets them execute.	Safety & Data Protection

5.2 Performance and capacity

ID	Requirement	Verified by
NFR-2.1	Ordinary screens respond within about two seconds on a dataset of several thousand ideas.	Scalability - Vertical & Performance
NFR-2.2	List endpoints page their results; no endpoint may return an unbounded set.	Scalability - Vertical & Performance
NFR-2.3	Adding an organisation must not degrade any other organisation.	Scalability - Horizontal
NFR-2.4	Database connections are pooled within a bound, so that the number of organisations cannot exhaust the server's connection limit.	Scalability - Horizontal
NFR-2.5	Request rates are limited per address, and per organisation against its plan allowance, with a grace band so that reaching a limit cannot take a workspace fully offline.	Scalability - Horizontal

5.3 Reliability and availability

ID	Requirement	Verified by
NFR-3.1	A failure in an outbound integration must not fail the action that triggered it. An approval is recorded even when notification cannot be sent.	Reliability & Fault Tolerance
NFR-3.2	A failure to write a log or an audit convenience record must never fail the operation it describes.	Reliability & Fault Tolerance

ID	Requirement	Verified by
NFR-3.3	Where a transport is unreachable, the system falls back to an alternative if one is configured and stops retrying the dead route for a period, so a user is not made to wait out a timeout on every attempt.	Reliability & Fault Tolerance
NFR-3.4	Concurrent identical requests must not produce duplicate records.	Reliability & Fault Tolerance
NFR-3.5	Schema changes are applied by recorded, forward-only migrations, and a newly created database must be identical to a fully migrated one.	Data Integrity & Recovery

5.4 Usability, accessibility and operability

ID	Requirement	Verified by
NFR-4.1	The interface is available in seven languages, complete in each; a missing translation falls back to English rather than showing a key.	Extensibility & Future Scope
NFR-4.2	Every failure message names the cause and the next action.	Observability & Operations
NFR-4.3	Configuration that an operator must change is reachable from a screen, not only from a deployment.	Observability & Operations
NFR-4.4	A status panel must never report success for a route it has not proved. "Accepted by the gateway" is reported as such and not as "delivered".	Observability & Operations
NFR-4.5	Logs record what happened without recording the contents of any message, code or password.	Observability & Operations

5.5 Privacy

ID	Requirement	Verified by
NFR-5.1	Personal data stays inside the organisation that owns it. Platform-level views count rows; they never list their contents.	Security & Multi-Tenancy
NFR-5.2	Recipients are masked wherever a delivery is recorded, so no operational table can become a contact directory.	One-Time Codes
NFR-5.3	With no AI provider configured - the default - no idea text leaves the system.	Safety & Data Protection

6. Data requirements

The registry holds 15 tables describing which organisations exist, the platform's own staff, subscription and payment records, one-time codes, and the delivery log. Each organisation database holds 17 tables covering its people, ideas, votes, comments, workflow, categories, challenges, notifications and settings.

Data	Requirement
One-time codes	Identifier, purpose, channel actually used, hashed code, attempt count, expiry and consumption time. Retained briefly after use as evidence that an address or number was verified, then pruned.
Delivery log	Provider, purpose, masked recipient, template, outcome, gateway reference. Never the message body.
Money	Whole paise. Never a decimal - 2500.10 has no exact binary form and the error compounds through tax and refund.
Audit	Who, what, when, for every decision and administrative action.
Attachments	Stored outside the database; the current hosting tier does not preserve them across a restart, which is recorded in section 8 as a limitation.

7. Verification

Requirements are verified by an executable suite that drives the real application over HTTP against scratch databases, and records for every case what was expected, what happened and when. The current run is 248 cases, all passing. The suite is deliberately prevented from reaching any external service: the text gateway is replaced by a mock that writes the message to a log, and no mail account is configured, so a test run can neither bill a gateway nor send a message to a real person.

Area	Cases
One-Time Codes (SMS & Email)	19
Authentication	12
Safety & Data Protection	40
Reliability & Fault Tolerance	24
Scalability - Vertical & Performance	21
Extensibility & Future Scope	18
Data Integrity & Recovery	18
Scalability - Horizontal	16
Platform Admin	10
Observability & Operations	8
Ideas	8
QCMS Integration	7
Org Admin / Users, Voting & Community	6 each
Comments, Review & Approval, Security & Multi-Tenancy	5 each
Categories & Challenges, Analytics & Reports	4 each
Notifications, Reports & Export, Branding & Settings, Support	3 each

A separate developer suite of 46 cases runs on every change and covers the same security properties at unit level.

8. Requirements not fully met

Listed rather than omitted. A specification that records only what works is not a specification, and each of these is a decision somebody should be able to revisit.

Item	Position
Uploaded files do not survive a restart	The current hosting tier has an ephemeral disk. Attachment rows persist while the files do not. Resolved by object storage or a persistent volume.
Outbound SMTP is blocked on the current host	Mail is therefore sent over the provider's HTTPS API. Requires the API credential to be configured; without it, email cannot be delivered from that host at all.
Only one text template registration is in use	Every purpose is sent under the activation registration, so a sign-in code reads as an activation message. Correct when the remaining approved wordings are supplied.
The service sleeps when idle	The first request after a period of inactivity is slow. A consequence of the hosting tier, not of the application.
No automated restore drill	Backups are taken; restoring one has not been exercised on a schedule. A backup that has never been restored is a hypothesis.

End of specification. Where this document and the running system disagree, the system is the fact and this document is the defect - raise it so that one of the two is corrected.